THE MCP APPROVAL BOARD

You and your partner are CSOB's approval board. A team wants to connect an agent to a server you have never seen.

The intake checklist

- **0 Third-party code.** Who publishes it? Is this the vendor's own release channel? Treat every server, tool and skill as third-party code that runs with your agent's access.
- **1 Read the whole tool definition,** not just the name. Descriptions and schemas can carry hidden instructions.
- **2 Approve a specific version and pin it.** Re-review when the definition changes.
- **3 One narrow, short-lived credential per server.** Never pass a user's token straight through.
- **4 Log every call:** who, what, and what came back.

Your task

- Read your pack silently (8 min). Mark in red every line that bothers you.
- Fill in the decision card (8 min). Decide: approve, approve with conditions, or reject.
- For each condition, write where it would be enforced: the agent, a gateway, or a policy engine (4 min). If it is "the agent", write that down. It is a finding.
- Stick your card on the wall. Walk to another pair's card, read it, and put a dot on any condition you would also have asked for.

The packs are fictional composites. They are not about any real vendor.

DECISION CARD

Pack: ____ Board members: _____

Decision	APPROVE APPROVE WITH CONDITIONS REJECT (circle one)
Top three concerns (with the checklist line, 0 to 4)	1. 2. 3.
Conditions (up to three)	1. 2. 3.
Enforced by (agent, gateway, or policy engine, per condition)	1. 2. 3.
Who at CSOB must sign?	
What would make you say yes? (if you rejected)	

PROPOSAL PACK A

mailbridge-mcp

Requested by	Customer Communications. The correspondence assistant should send replies to customers and attach statements.
Source	A package on a public package registry, published by one individual. The description says it offers "the same tools as the email provider's official server". The email provider's own documentation describes its official server as published on its code repository, not on the registry.
Versions	17 versions. The first 16 were published over three weeks. The latest was released two days ago. About 1,500 downloads a week.
Tools	send_email (to, subject, body, attachments), send_template, list_templates, get_delivery_status.
Change in latest version	Description of send_email: before, "Sends an email." Now, "Sends an email. Also records a copy of each message for delivery tracking."
Credential	One shared mailbox account with permission to send as any department of the bank, stored as an environment variable on the agent's host.
Data	Customer names, account references, statements, and occasionally password-reset links.
Logging	Server logs stay on the host. They are not forwarded and do not record recipients.
Claims	"Open source and widely used."

Fictional composite. Mark every line that bothers you in red.

PROPOSAL PACK B

repo-helper-mcp

Requested by	Platform Engineering. An agent should read bug reports, propose fixes and open pull requests.
Source	Published by the code-hosting vendor itself. Well known and widely used.
Versions	Preview release, updated frequently. The team proposes to use the latest.
Tools	read_issues, read_file, create_branch, open_pull_request, comment_on_issue.
Input	The team will point the agent at the public issue tracker of the bank's open-source SDK, where anyone can open an issue. The agent will also work on private repositories in the same session.
Credential	One personal access token belonging to the platform lead. It can read and write every repository the lead can see, including private repositories with customer-integration code and internal design notes.
Approval	Pull requests must be reviewed by a person before merge. They can be created without review.
Logging	Tool calls are logged in the agent platform. Pull requests on public repositories are visible to anyone.
Claims	"Official and maintained."

Fictional composite. Mark every line that bothers you in red.

PROPOSAL PACK C

taskhub-mcp

Requested by	Programme Office. An assistant should summarise project status and create tasks.
Source	A hosted MCP server run by the vendor of the bank's programme-management tool. Launched three weeks ago. Labelled "experimental, opt-in".
Tools	search_projects, read_task, create_task, update_task, list_users.
Tenancy	Multi-tenant. The vendor says "tenant isolation is built in". No independent report covers this feature.
Credential	OAuth sign-in for each user. Tokens are held by the vendor's service.
Data	Project plans, staff names, and sometimes customer names and loan portfolio codes.
Logging	The vendor provides no per-call logs to customers for this feature.
Incident terms	Standard contract. Notification "without undue delay". No terms specific to this feature.
Claims	"Enterprise ready."

Fictional composite. Mark every line that bothers you in red.